

FUNDAMENTALS · WEB SECURITY · DEEP DIVE NOTES

Module 4: HTTP vs HTTPS

Plaintext Vulnerability vs Cryptographic Privacy, Integrity & Identity

Author & Educator Notes · Submodule 04 · Target Audience: CS / Web Engineering Students

The Golden Security Rule: *The internet is a public network of untrusted intermediary routers. When you transmit data over plain HTTP, every entity between your laptop and the server — your Wi-Fi router, local ISP, backbone provider, and government tap — can **read**, **alter**, or **impersonate** that traffic. **HTTPS** turns a public megaphone into a sealed cryptographic tunnel.*

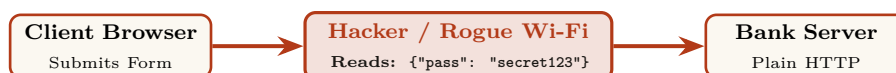
1 The Plaintext Nightmare: The 3 Fatal Vulnerabilities of HTTP

WHY HTTP IS BROKEN BY DESIGN FOR MODERN LIFE

HTTP communicates in pure, unencrypted ASCII text. When you submit a login form over HTTP, your packet travels across 12+ independent physical hops. This exposes users to three deadly attacks:

1. **Eavesdropping (Sniffing):** Anyone running Wireshark or `tcpdump` on the same coffee shop Wi-Fi sees your session cookie, password, and credit card number in plain text.
2. **Tampering (Man-in-the-Middle / MitM):** A rogue proxy or ISP can modify the HTML on the fly — injecting malicious crypto-mining scripts, swapping banking payment details, or injecting spam ads.
3. **Impersonation (Spoofing):** A hacker can poison your DNS and route your browser to a clone of your bank. Without certificates, your browser has zero mathematical proof of who it is talking to.

1. PLAIN HTTP (PORT 80) — TRANSPARENT PLAINTEXT TO EVERY HOP



2. HTTPS (PORT 443) — ENCRYPTED TLS 1.3 TUNNEL



2 What HTTPS Really Is: The CIA Triad

HTTPS ARCHITECTURE: HTTPS = HTTP + TLS

DEFINITION

HTTPS is not a distinct transport protocol. It is standard **HTTP** running inside an encrypted session managed by **TLS** (Transport Layer Security, previously called SSL).

DEFAULT PORT

Port 443 (Standard HTTP uses Port 80).

THE 3 PILLARS

1. Confidentiality (Privacy via Encryption) **2. Integrity** (Anti-Tampering via Message Authentication Codes) **3. Authenticity** (Identity verification via X.509 Certificates).

2.1 The Hybrid Cryptography Solution

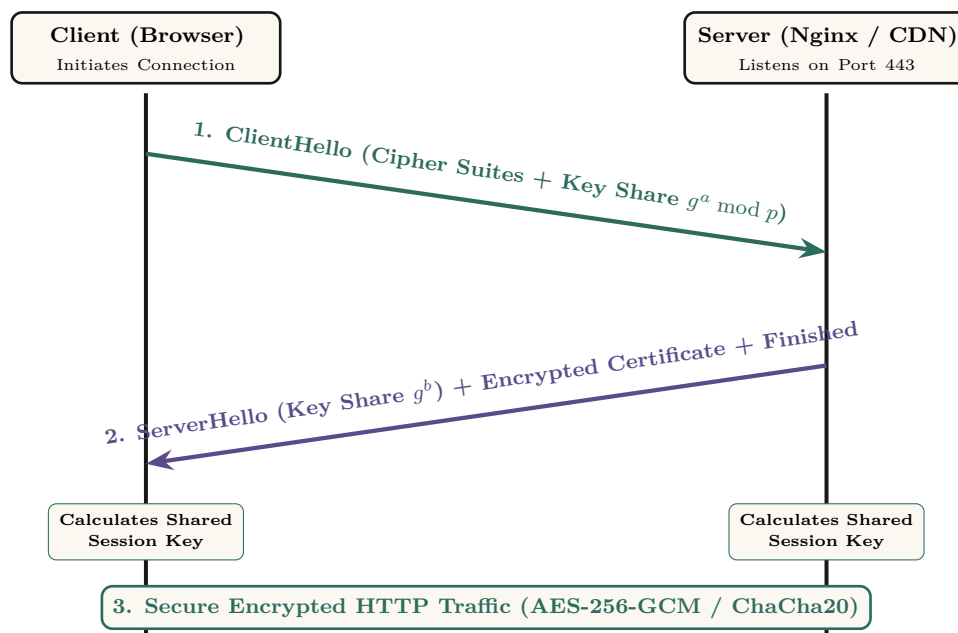
THE CRYPTOGRAPHIC DILEMMA

- **Asymmetric Cryptography (Public/Private Keys like RSA / ECC):** Allows two strangers to securely exchange secrets across a public channel. But it is $1000\times$ **slower on CPU** and burns massive server battery/compute.
- **Symmetric Cryptography (Shared Secret Key like AES-256-GCM / ChaCha20):** Incredibly fast (gigabits/sec using hardware AES-NI instructions). But how do the client and server agree on the shared secret key without an eavesdropper overhearing it?

THE HYBRID BREAKTHROUGH

HTTPS uses **Asymmetric Cryptography** only for the first 1-RTT handshake to verify identity and negotiate a temporary session key (Diffie-Hellman). Once established, both parties switch immediately to **Symmetric Cryptography** for all HTTP web data.

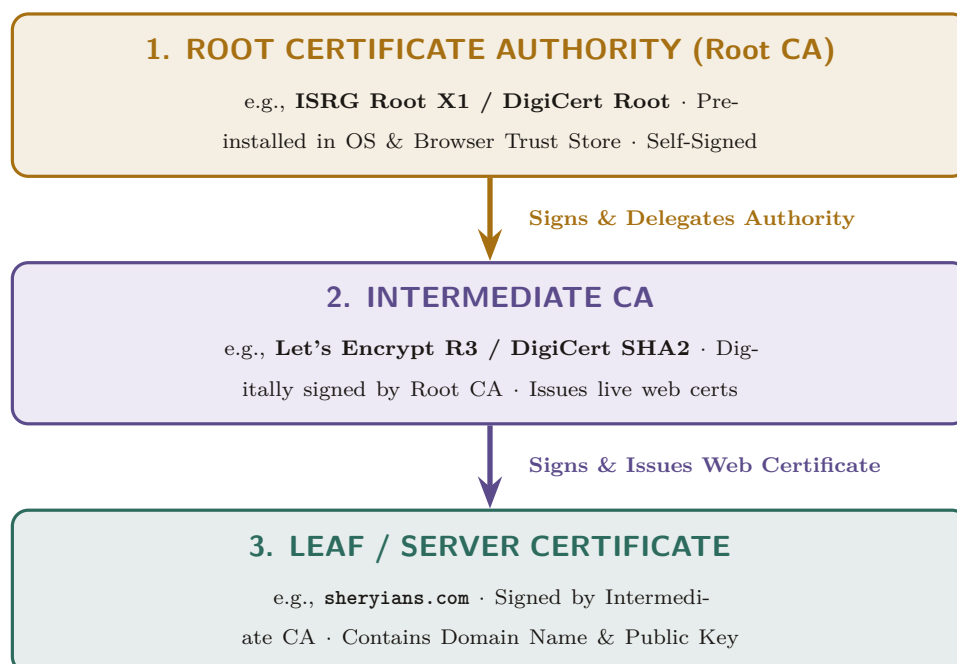
3 The Modern TLS 1.3 Handshake (RFC 8446)



4 The Chain of Trust: How Browsers Verify Server Identity

X.509 DIGITAL CERTIFICATES & CERTIFICATE AUTHORITIES (CAs)

WHAT IS A CA?	A globally trusted organization (e.g., Let's Encrypt, DigiCert) that cryptographically signs domain certificates after verifying ownership.
ROOT STORE	Your operating system (Windows, macOS, Linux) and browser ship with a built-in list of ≈ 150 trusted Root CAs .
THE SIGNATURE CHAIN	A hacker cannot forge a certificate for <code>google.com</code> because they do not possess Google's private key, nor do they possess a trusted CA's private key.



■ WHY DO STUDENTS SEE THE RED WARNING SCREEN?

“Jab aap localhost ya kisi random site par jate ho aur browser chillata hai: ‘**Your connection is not private (NET::ERR_CERT_AUTHORITY_INVALID)**’, iska kya matlab hai? Iska matlab hai certificate kisi trusted Root CA dwara signed nahi hai (Self-signed certificate hai), ya certificate expire ho chuka hai, ya URL domain aur certificate domain match nahi kar rahe. **Browser aapko hacker ke impersonation se bacha raha hai.**”

5 Master Comparison Matrix: HTTP vs HTTPS

Feature	HTTP (Hypertext Transfer Protocol)	HTTPS (HTTP Secure)
Default Port	Port 80	Port 443
Data Format	Clear, human-readable ASCII text	Opaque binary ciphertext
Security Layer	None (Vulnerable to MitM, Sniffing)	TLS 1.3 / SSL encryption layer
Confidentiality	Zero (Anyone on the network can read)	Mathematically unbreakable (AES-GCM-256)
Integrity	Zero (Proxies/ISPs can alter content)	Cryptographic MAC verification (Anti-tamper)
Authentication	None (Zero proof of server identity)	Verified via X.509 CA Certificate Chain
Browser Status	Marked “Not Secure”	Marked secure with padlock icon
SEO & Search Rank	Heavily penalized by Google search	Provides official SEO ranking boost
Modern Web APIs	Blocked (No Camera, Mic, Geolocation)	Fully unlocked
Next-Gen Protocols	HTTP/2 & HTTP/3 cannot run	Mandatory prerequisite for HTTP/2 & HTTP/3

6 Recap: Blackboard Summary & The One-Line Spine

The One-Line Spine of Web Security

CORE TAKEAWAY CHAIN FOR THE BOARD

HTTP sends plaintext $\Rightarrow$ Anyone can sniff, tamper, or spoof $\rightarrow$ Add TLS Layer (Port 443)

How to establish trust without prior secrets? $\rightarrow$ X.509 Digital Certificates + CA Chain of Trust

Asymmetric is too slow for big files? $\rightarrow$

Hybrid: Asymmetric Handshake $\rightarrow$ Lightning-Fast Symmetric AES Encryption

■ THE POSTCARD VS SAFE ANALOGY

“*Poori kahani ka ek summary:*

HTTP ek Postcard hai. Raste mein postman, delivery boy, padosi — koi bhi aapka sandesh padh sakta hai aur pen se text badal bhi sakta hai.

HTTPS ek Titanium Safe hai jisme number lock laga hai. Raste mein safe sabko dikhega, par use khol sirf wahi sakta hai jiske paas cryptographic key ho!”